

SecureShare — Software Requirements Specification

Developed in Conformance with IEEE 29148 Standard for Requirements Engineering

Project: SecureShare | Standard: IEEE 29148 | Version: 1.0.0 | Date: October 2026
Authors: Sushmitha Reddy, Rahul Kumar, Priya Sharma, Arjun Rao

1. Scope

- 1.1 Identification: SecureShare Enterprise File Protection & Continuous Security Platform v1.0.0.
- 1.2 System Overview: A zero-trust web application pairing client file sharing with real-time malware inspection, AES-256-GCM envelope encryption, tamper-evident audit logging, and automated CI/CD security validation.
- 1.3 Document Overview: Formatted according to IEEE 29148:2018 clause recommendations for system requirements.

2. Referenced Documents & Standards

- IEEE 29148:2018 — Systems and Software Engineering — Requirements Engineering.
- NIST SP 800-53 Rev. 5 — Security and Privacy Controls for Information Systems.
- ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection.
- OWASP Top 10:2021 — The Ten Most Critical Web Application Security Risks.
- FIPS 197 — Advanced Encryption Standard (AES) Specification (AES-256-GCM).
- RFC 6238 — TOTP: Time-Based One-Time Password Algorithm.

3. Requirements Engineering Method

Requirements were elicited using STRIDE threat modeling, stakeholder personas (Security Auditor, System Admin, End User), and abuse case analysis. Requirements are specified using RFC 2119 imperatives (SHALL, MUST, SHOULD) and validated through automated pytest security suites and DevSecOps pipelines.

4. System Overview & Context

The platform mediates all file interactions through a 3-tier boundary architecture: Untrusted Client Browser, DMZ Reverse Proxy, and Authenticated Application Tier, backed by isolated POSIX volumes (/uploads and /quarantine) and a PostgreSQL relational store.

5. Functional Requirements (FR-01 to FR-13)

The following table defines the 13 core functional capabilities required by SecureShare:

Req ID	Requirement Description	Security Module	IEEE 29148 Ref	Verification Method
FR-01	User Registration with Argon2id hash & complexity policy	Auth Service	Clause 5.1.1	Unit & Fuzz Test (SEC-TC-01)
FR-02	JWT authentication with short-lived tokens & sliding refresh	Auth Service	Clause 5.1.2	API Expiration Test (SEC-TC-04)
FR-03	Time-based One-Time Password (TOTP) Multi-Factor Auth	MFA Module	Clause 5.1.3	TOTP Verification Test (SEC-TC-06)
FR-04	Direct file upload with MIME & extension verification	Upload Pipeline	Clause 5.2.1	MIME Validation Test (SEC-TC-13)
FR-05	Automated 6-stage malware, macro, & entropy threat scanning	Scanner Engine	Clause 5.2.2	EICAR Scanner Test (SEC-TC-12)

Req ID	Requirement Description	Security Module	IEEE 29148 Ref	Verification Method
FR-06	Automated file quarantine isolation upon threat detection	Quarantine Module	Clause 5.2.3	Air-gap Download Test (SEC-TC-16)
FR-07	Envelope encryption using AES-256-GCM cipher & 96-bit nonce	Crypto Service	Clause 5.3.1	Cryptographic Test (SEC-TC-17)
FR-08	Authorized file download with real-time decrypt-on-the-fly	Download Manager	Clause 5.3.2	Decryption Stream Test (SEC-TC-18)
FR-09	Hierarchical folder tree organization with BOLA prevention	Folder Manager	Clause 5.4.1	BOLA Isolation Test (SEC-TC-08)
FR-10	Granular permission sharing (VIEWER, DOWNLOADER, EDITOR)	Permission Service	Clause 5.4.2	DAC Matrix Test (SEC-TC-10)
FR-11	Expiring public link sharing with password & download limit	Share Link Engine	Clause 5.4.3	Share Link Test (SEC-TC-20)
FR-12	Tamper-evident audit logging with SHA-256 hash chaining	Audit Verifier	Clause 5.5.1	Hash Chain Verifier (SEC-TC-24)
FR-13	SOC Admin & Auditor Security Dashboard with live telemetry	Admin Portal	Clause 5.5.2	Integration Test (SEC-TC-10)

6. Security Requirements (SR-01 to SR-15)

Security Req ID	Requirement Statement	Threat Mitigated	Target Component	Status
SR-01	Protection against Broken Object Level Authorization (BOLA)	S-01, I-02	Access Layer	PASS
SR-02	Zero plaintext credentials or encryption keys in database	I-01, T-01	Crypto Service	PASS
SR-03	Strict Content-Security-Policy & anti-clickjacking headers	I-01, S-02	HTTP Middleware	PASS
SR-04	Sliding-window IP and account rate limiting (5 req/min auth)	S-01, D-02	Rate Limiter	PASS
SR-05	Immutable audit log trail with continuous integrity verification	T-02, R-01	Audit Subsystem	PASS
SR-06	Automatic account lockout after 5 consecutive failed logins	S-01	Auth Service	PASS
SR-07	File quarantine air-gap preventing download of suspicious files	T-01, E-02	Quarantine Module	PASS
SR-08	Role-based authorization hierarchy (ADMIN, AUDITOR, USER)	E-01	RBAC Engine	PASS
SR-09	Automated SAST & Secret scanning gate in CI/CD pipeline	I-01, S-02	DevSecOps	PASS
SR-10	Containerized microservice sandboxing with non-root UID	E-02	Docker / K8s	PASS
SR-11	MIME type verification independent of user file extension	T-01, E-02	Scanner Engine	PASS
SR-12	Cryptographic IV randomization: unique 96-bit IV per file	T-01	Crypto Service	PASS
SR-13	Secure public link password hashing via bcrypt/Argon2	S-01	Share Engine	PASS
SR-14	OWASP ZAP DAST automated vulnerability testing compliance	All OWASP	CI/CD Pipeline	PASS
SR-15	Fuzz testing resistance on authentication and upload endpoints	D-01, E-02	Test Framework	PASS

7. Interface Requirements

- User Interface: Responsive single-page application built in React 18, TypeScript, and Tailwind CSS.
- Application Programming Interface: OpenAPI 3.0 documented REST endpoints adhering to JSON schema contracts.
- Data Store Interfaces: SQLAlchemy ORM connection pooling over TLS to PostgreSQL/SQLite.
- External Security Scanners: Local Unix domain socket / ClamAV daemon protocol for zero-network scanning.

8. Performance & Scalability Requirements

- File upload and envelope encryption processing throughput ≥ 25 MB/s on standard CPU cores.
- Decryption-on-the-fly streaming latency < 150 ms time-to-first-byte.
- Sliding-window rate limiter memory overhead < 50 MB for 100,000 active client IP records.
- Audit ledger cryptographic verification speed $> 5,000$ rows/second.

9. Design Constraints & Security Mandates

- Operating Systems: Windows, Linux (Debian 12 / Alpine), containerized OCI containers.
- Sandboxing: Non-root container UID (10001) with read-only root filesystems where applicable.
- Secret Management: All cryptographic master keys sourced exclusively from environment variables.

10. Verification & Traceability Matrix

100% of functional requirements (FR-01 to FR-13) and security requirements (SR-01 to SR-15) are mapped to automated test suites SEC-TC-01 through SEC-TC-28, resulting in 48 passing automated tests in the test suite.